



Security Controls in Shared Repositories

Rachel Shaw – CSD380 – 7/20/25

Introduction

- Code repositories are a crucial part of the software development process.
- This makes them a primary target for threat actors hoping to exploit or create vulnerabilities in a project.
- When a repository is shared amongst multiple team members the attack surface increases

Common threats to repositories:

- Unauthorized access
- Exposed Secrets
- Malware injection
- Dependency Vulnerabilities
- Supply chain attacks



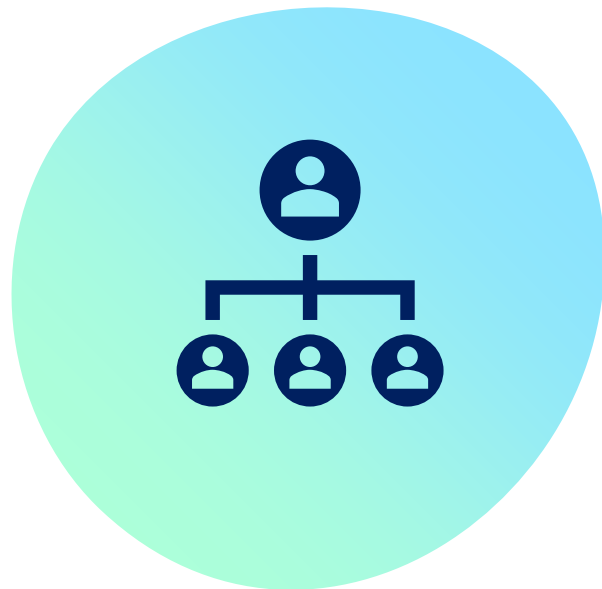
Best Practice 1: Strong Authentication and Authorization mechanisms



- Use strong authentication and authorization methods such as:
 - Tokens
 - Passwords
 - Keys
 - Biometrics
- To double down, use multi-factor authentication, utilizing more than one of these methods
- This ensures only authorized users can access the repository

Best Practice 2: Role-based Access control

- Access control mechanisms determine what team members can access, modify, or remove certain resources in the repository.
- Role-based access control restricts team members to the controls they need to complete their tasks.
 - For example, if a team member is responsible for reviewing a file, they should only be allowed to read it.
- In the case that an unauthorized user gains access to the repository through impersonation, their attack surface is limited.



Best Practice 3: Monitor Repository Activity



- Monitor updates to the repository for unusual activity
- Set up automated alerts for suspicious or irregular events
 - There are several automated tools that can do this for you such as:
 - Gitleaks
 - Harness Code Repository
 - SonarQube

Best Practice 4: Avoid Dangerous Workflows

- Some shared repository services such as GitHub Actions use "unsafe configurations"
 - These configurations can:
 - Grant excessive permissions
 - Use untrusted third party actions
 - Leave secrets vulnerable in the CI/CD pipeline
- To avoid harm caused by these configurations, ensure all third party tools/actions are secure so that they do not become a liability in the workflow.



Best Practice 5: Enforce Code Signing



- Code signing is the process of cryptographically signing each component of the software to ensure it has not been modified since it was signed by a trusted user.
- Code signing is crucial to ensuring code integrity in shared repositories.
- It also prevents unauthorized alteration as signatures can be validated as legitimate, making it harder for threat actors to inject malicious code.

Best Practice 6: Back up and Restore Code Frequently

- Backups are essential to ensuring code integrity in the instance of an attack or human error.
- They can help recover code after a security breach or data loss.
- Backing up the repository frequently means that the team will be prepared.
- It is also best to test restore process to make sure it will work when needed.



Conclusion

- Code Repositories are a huge target for threat actors
- Code repositories that are used by multiple members of a team provide a larger attack surface for these malicious users.
- To protect your team's repositories, follow the following best practices:
 - Use Secure authorization methods and enable two-factor authentication
 - Implement Role-based access control
 - Monitor Repository activity for unusual or harmful activity
 - Avoid dangerous workflows that rely too much on third party resources
 - Enforce code signing to ensure each change is made by a trusted user
 - Backup and restore repositories regularly incase something goes wrong



References

Harness. (2025, June 26). *Best Practices for Securing Code Repositories*. Harness.io; harness.io. <https://www.harness.io/harness-devops-academy/secure-code-repositories-best-practices>

LinkedIn. (2025). *What are the best practices for securing your code repositories?* LinkedIn.com. <https://www.linkedin.com/advice/0/what-best-practices-securing-your-code-repositories>

Rose, J. (2025, June 11). *12 Best Practices for Secure Code Repositories (2025 Guide)*. Checkmarx. <https://checkmarx.com/supply-chain-security/repository-health-monitoring-part-2-essential-practices-for-secure-repositories/>

